SEC-130: CYBER SECURITY

UNIT-II: Email risk, Different types of attacks, IT laws

Email Risks

- **Electronic mail (email)** is among the most extensively utilized communication mediums, both in institutional and personal contexts.
- Email, owing to its widespread adoption and its inherently open architecture, is **one of the most frequently exploited vectors for security attacks**.

Email Risks – ***Risks***

- **Phishing:** The practice of **sending fraudulent emails that impersonate a legitimate individual, organization, or institution**, with the objective of deceiving the recipient into **disclosing confidential information** or into **performing an unintended action**.

- **Malware Distribution:** The **use of email as a delivery mechanism for malicious software**, typically embedded within attachments or hyperlinks.

Email Risks – *Risks (Contd.)*

- **Spoofing: The falsification of the sender's address field within an email**, such that the message appears to originate from a legitimate or trusted source.
- **Interception and Eavesdropping:** The **unauthorized interception of email messages during transmission across a network**, particularly where the communication channel is not encrypted.
- **Spam: The receipt of unsolicited, typically bulk-distributed, email messages**.

Email Risks – *Control mechanisms*

- Filtering
- Encryption
- Authentication mechanisms
- User awareness
- Etc…

Spam

- **Spam refers to unsolicited electronic messages, typically distributed in bulk to a large number of recipients simultaneously.**
- It is generally done for the purpose of **Advertising, Fraud** or **Distribution of malicious content.**

Spam – ***Characteristics***

- Distribution to a large number of recipients through a single, often automated, sending operation.
- Frequent use of misleading or deceptive subject lines intended to induce the recipient to open the message.
- Commercial content, such as advertisements for unauthorized pharmaceuticals, counterfeit goods, or fraudulent financial schemes.
- Frequent inclusion of malicious hyperlinks or attachments.

Spam – ***Consequences***

- **Resource consumption:** Spam consumes network bandwidth, mail server storage, and processing capacity.
- **Productivity loss:** Considerable time is expended by recipients in identifying and discarding unsolicited messages.
- **Security exposure:** A substantial proportion of spam serves as a delivery mechanism for phishing attempts and malware

Spam – *Countermeasures*

- **Spam filters: Automated systems that analyze incoming messages against defined rules, sender reputation data, and content patterns**, in order to identify and segregate suspected spam prior to delivery to the recipient's inbox.
- **Blacklisting: The maintenance of lists of known spam-originating domains or IP addresses.**

Spam – *Countermeasures (Contd.)*

- **Authentication protocols: The implementation of sender verification mechanisms**, such as the **Sender Policy Framework (SPF)**, **DomainKeys Identified Mail (DKIM)**, and **Domain-based Message Authentication**, **Reporting and Conformance (DMARC)**.

- **User vigilance: The exercise of caution by recipients in refraining from responding to, or interacting with, unsolicited messages.**

Email Protocols

- An email protocol refers to a **standardized set of rules that governs the manner in which electronic mail messages are composed, transmitted, received, and stored across a network.**

Email Protocols - ***SMTP***

- SMTP stands for **Simple Mail Transfer Protocol.**
- SMTP is used in the **transmission of outgoing email messages from a sender's mail client to a mail server, and subsequently between mail servers, until the message reaches the recipient's designated mail server**.
- SMTP operates on **port 25** by default, although alternative ports (such as **587**, **with encryption**) are commonly employed in contemporary implementations.

Email Protocols – *SMTP (Contd.)*

- **SMTP does not provide functionality for the retrieval or storage of messages by the recipient.**
- In its original specification, **SMTP does not incorporate encryption**, **rendering transmitted content susceptible to interception.**

Email Protocols - *POP3*

- POP3 stands for **Post Office Protocol Version 3**
- POP3 is used for the **retrieval of email messages from a mail server to a local client device.**
- Messages are typically downloaded to the client device and, depending on configuration, subsequently removed from the server.
- POP3 operates on **port 110** by default, with a **secure variant operating on port 995**.

Email Protocols - *IMAP*

- IMAP stands for **Internet Message Access Protocol**
- IMAP is used for the **retrieval of email messages, wherein messages are retained on the mail server and synchronized across multiple client devices.**
- IMAP operates on **port 143** by default, with a **secure variant operating on port 993**.

Email Protocols – *POP3 vs IMAP*

Comparison of POP3 and IMAP:

Feature	POP3	IMAP
Message storage	Typically downloaded and removed from server	Retained on server
Multi-device access	Limited	Fully supported
Synchronization	Not supported	Supported
Default port	110	143

Basics of Internet Protocol (IP)

- The **Internet Protocol (IP)** is the fundamental **network-layer protocol**.
- It is reponsible for the **addressing and routing of data packets across interconnected networks**.
- It **enables data to be transmitted from a source device to a destination** device across the internet or any other IP-based network.

Basics of Internet Protocol (IP) – *Core functions*

1. Addressing: Assigns a unique numerical identifier, called *IP address*, to each device connected to a network, enabling devices to be individually identified and located.

2. Packet fragmentation & encapsulation: IP divides data into discrete units known as *packets*, each of which is transmitted independently and subsequently reassembled at the destination.

Basics of Internet Protocol (IP) – *Core functions (contd.)*

3. Routing: IP facilitates the determination of the path by which a packet travels from its source to its destination, traversing intermediate devices known as *routers*.

Basics of Internet Protocol (IP) – *Addressing versions*

- **IPv4 (Internet Protocol version 4)**
  - Consists of a **32-bit numerical address**
  - Conventionally represented in **dotted-decimal notation (for example, 192.168.1.1)**
  - Provides a finite address space of approximately **4.3 billion unique addresses**
  - Has proven **insufficient to accommodate the continued growth of internet-connected devices**

Basics of Internet Protocol (IP) – *Addressing versions (contd.)*

- **IPv6 (Internet Protocol version 6)**
  - Consists of a **128-bit numerical address**
  - Developed to **address the limitations of IPv4 by providing a substantially larger address space**
  - **More recent addressing scheme**

Basics of Internet Protocol (IP) – *Relevance to information security*

- **No mechanisms for encryption, authentication, or verification of data integrity.**
- **Susceptible to interception, spoofing and unauthorized modification during transit.**

Email Security – *Web Authentication*

- Web Authentication refers to the **set of mechanisms employed to verify the identity of a user or system prior to granting access to a web-based application, service, or resource**.
- Web Authentication also **ensures that the systems with which a user communicates are themselves genuine**.

Email Security – *Web Authentication -- mechanisms*

- **Credential-based authentication: Verification of a user's identity through a username and password combination.**
- **Token-based authentication: The issuance of a temporary digital token following successful initial authentication, then used by the client to authenticate further requests.**

Email Security – *Web Authentication -- mechanisms (contd.)*

- **Certificate-based authentication: The use of digital certificates, issued by a trusted Certificate Authority (CA), to verify the identity of a server.**
- **Multi-factor authentication**

Email Security – *Secure Sockets Layer (SSL)*

- Secure Sockets Layer (SSL) is a **cryptographic protocol designed to establish a secure, encrypted communication channel between a client** (such as a web browser or email client) **and a server**
- SSL has been **succeeded by its more recent counterpart, Transport Layer Security (TLS)**

Email Security – *Secure Sockets Layer (SSL) -- Principal functions*

1. **Encryption:**
   - SSL **encrypts data transmitted between the client and server**
   - **Makes interpreting content hard without decryption key** if intercepted

Email Security – *Secure Sockets Layer (SSL) -- Principal functions (contd.)*

2. Authentication:

- SSL **employs digital certificates, issued by a trusted Certificate Authority, to verify the identity of the server.**

Email Security – *Secure Sockets Layer (SSL) -- Principal functions (contd.)*

3. Data integrity:

- SSL **incorporates mechanisms to detect any unauthorized alteration of data during transmission**

Email Security – *Secure Sockets Layer (SSL) -- Operation*

1. Client initiates a connection to the server and requests a secure session.

2. Server presents its digital certificate, containing its public key, to the client.

3. Client verifies the authenticity of the certificate against a trusted Certificate Authority.

4. Upon successful verification, the client and server negotiate a shared encryption key, subsequently used to encrypt all further communication within the session.

Email Security – *Secure Electronic Transaction (SET)*

- **Secure Electronic Transaction (SET)** is a **security protocol developed specifically to secure electronic payment transactions over the internet**, particularly those involving payment card (credit or debit card) information.
- Main objective is **protecting the confidentiality and integrity of payment data** exchanged between a purchaser, a merchant, and a financial institution.

Email Security – *Secure Electronic Transaction (SET) -- Principal objectives*

1. **Confidentiality of payment information: Ensures that payment card details are encrypted and are not directly accessible to the merchant**

2. **Integrity of transaction data: Ensures that transaction details cannot be altered without detection**

3. **Authentication of all parties: Employs digital certificates to verify the identities of the purchaser, the merchant, and the financial institution**

Email Security – *Secure Electronic Transaction (SET) -- Principal objectives (contd.)*

4. Interoperability: SET was designed to function consistently across differing hardware, software, and financial institutions, thereby **enabling broad adoption across the payment card industry**.

Email Security – *Difference between SSL & SET*

SSL provides a general-purpose secure communication channel applicable to any form of data exchange. While SET was purpose-built specifically for securing payment card transactions.

Network Attacks

- A Network Attack refers to **any deliberate attempt to exploit a weakness in a network, protocol, application, or system**
- Performed for **gaining unauthorized access**, **disrupting normal operation**, or **compromising the confidentiality, integrity, or availability of data**

Network Attacks – *Buffer Overflow*

- A Buffer Overflow refers to a **condition in which a program writes more data into a fixed-size block of memory, known as a *buffer*, than the buffer has been allocated to hold**
- It causes the **excess data to overwrite adjacent memory locations**
- It **occurs when a program fails to verify that incoming data does not exceed this allocated size** before writing it into the buffer

Network Attacks – *Buffer Overflow (contd.)*

- Attackers exploit this weakness by deliberately **supplying more data than expected, structured in such a way that the overflow overwrites adjacent memory with malicious instructions**
- **Potentially causing the program to execute code supplied by the attacker** rather than its intended instructions.

Network Attacks – *Buffer Overflow -- Consequences*

- **May cause a program to crash**
- **Produce incorrect output**
- **Allow the attacker to execute arbitrary malicious code**

Network Attacks – *Buffer Overflow -- Prevention measures*

- Through **rigorous input validation**
- **Use of programming languages and libraries that automatically enforce memory boundary checks**
- Application of security features such as **address space layout randomization and non-executable memory regions**

Network Attacks – *TCP Session Hijacking*

- TCP Session Hijacking refers to **an attack in which an adversary takes over an established communication session between two parties over the Transmission Control Protocol (TCP)**.

- When TCP session is established between two devices **each device tracks the session using identifying values, including sequence numbers, which ensure that data packets are received in the correct order**.

Network Attacks – *TCP Session Hijacking (contd.)*

- The attacker **intercepts and exploits knowledge of the ongoing session, in order to inject their own packets into the session or to seize control of the session outright**
- The attacker **may gain access to any privileges or data that the legitimate, authenticated user of that session would otherwise possess**, without the need to independently authenticate.

Network Attacks – *Sequence Guessing*

- Sequence Guessing (or Sequence Number Prediction) refers to a technique **employed as part of a TCP session hijacking attack, in which an adversary predicts or estimates the sequence number of packets.**

- In order **to inject fraudulent packets into that session without the need to directly intercept legitimate traffic**.

Network Attacks – *Sequence Guessing (contd.)*

- It is possible typically **due to a predictable or weak sequence number generation mechanism**.
- This attack can be prevented principally through **the use of sufficiently randomized, unpredictable sequence number generation mechanisms** in the implementation of the TCP protocol.

Network Attacks – *SQL Injection Attack*

- An SQL Injection Attack refers to an attack in which **an adversary inserts malicious Structured Query Language (SQL) code into an input field of a web application**.
- The objective is to **manipulate the underlying database in a manner not intended by the application's developers**.

Network Attacks – *SQL Injection Attack (contd.)*

- This may permit the attacker **to retrieve unauthorized data from the database (including confidential records such as usernames and passwords)**, **modify or delete data without authorization**, or, in severe cases, **gain administrative control over the database system**.

Network Attacks – *SQL Injection Attack -- Prevention*

- Through **rigorous validation** and **sanitization of all user input**
- The **use of parameterized queries** (also known as ***prepared statements***)
- The **application of the principle of least privilege to database accounts used by web applications**

Network Attacks – *Cross-Site Scripting (XSS) Attack*

- A **Cross-Site Scripting (XSS) Attack refers to an attack in which an adversary injects malicious script code into a web page that is then viewed by other users, such that the malicious script executes within the browser of any user who views the compromised page**.

- This attack **exploits web applications that accept user-supplied input and subsequently display that input to other users without adequate validation or filtering**.

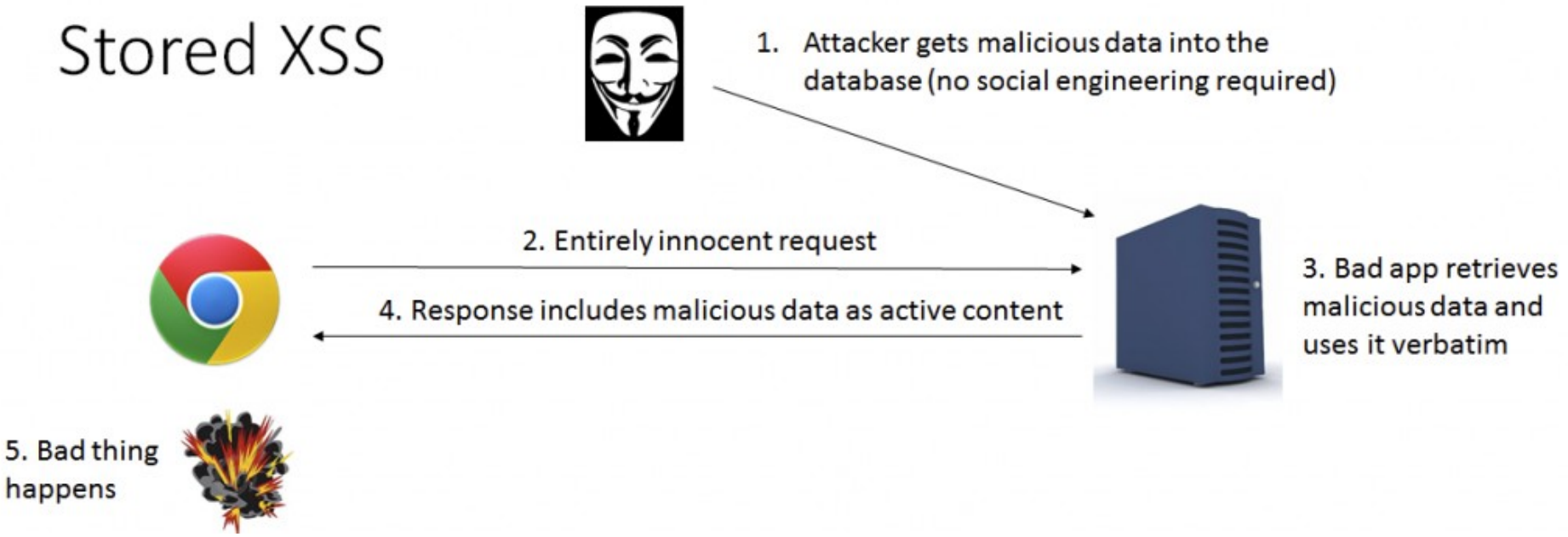
Network Attacks – *Cross-Site Scripting (XSS) Attack -- Consequences*

- It may be used to
  - **steal session cookies**
  - **capture keystrokes**
  - **redirect the victim to a fraudulent website**, or
  - **perform actions on the victim's behalf without their knowledge**

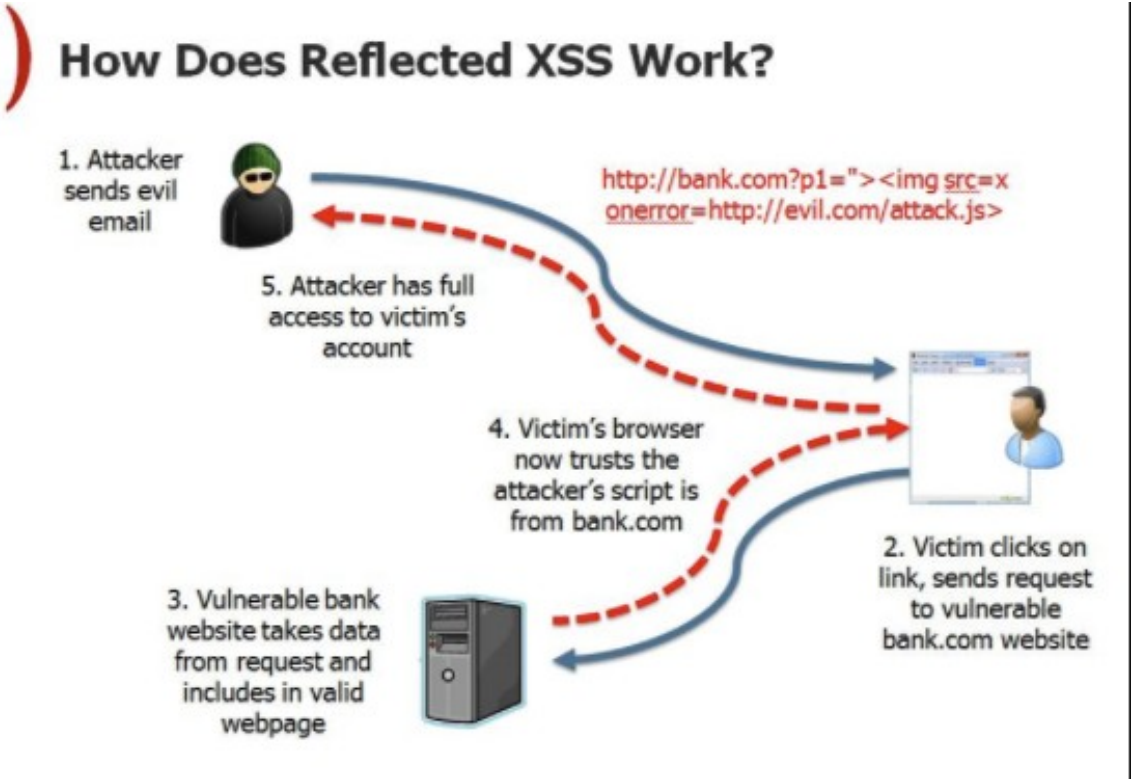
Network Attacks – *Cross-Site Scripting (XSS) Attack -- Categories*

- XSS Attack is classified into two categories:
  - **Stored**: **The malicious script is permanently saved on the target server** (for example, within a comment field) **and served to all subsequent visitors**
  - **Reflected**: **The malicious script is embedded within a request (such as a hyperlink) and is executed only when a victim follows that specific request**

Network Attacks – *Cross-Site Scripting (XSS) Attack – Categories: Stored*



Network Attacks – *Cross-Site Scripting (XSS) Attack – Categories: Reflected*



Network Attacks – *Cross-Site Scripting (XSS) Attack -- Prevention measures*

- This attack is mitigated through
  - **rigorous validation** and **sanitization of user input**
  - **the encoding of output displayed to users**, and
  - **the implementation of security policies**, **such as Content Security Policy**, within web applications.

Network Attacks - *Eavesdropping Attack*

- An Eavesdropping Attack refers to **an attack in which an adversary secretly monitors or intercepts communication transmitted between two parties over a network.**
- The primary objective is **to obtain confidential information**.
- This attack is a **passive attack**, the adversary does not alter the intercepted data.

Network Attacks - *Eavesdropping Attack*

- Eavesdropping is **particularly effective against un-encrypted communication as unencrypted data may be read directly**.
- Information commonly targeted includes **login credentials**, **financial information**, and **confidential business or personal communications**.

Network Attacks - *Eavesdropping Attack (contd.)*

- Eavesdropping is **particularly effective against un-encrypted communication as unencrypted data may be read directly**.
- Information commonly targeted includes **login credentials**, **financial information**, and **confidential business or personal communications**.

Network Attacks - *Eavesdropping Attack -- Prevention*

- This attack is **mitigated primarily through the encryption of data during transmission**, **such as through the use of SSL/TLS.**
- The **use of secure, trusted network connections** rather than open or unsecured public networks.

Network Attacks - *Eavesdropping Attack -- Prevention*

- This attack is **mitigated primarily through the encryption of data during transmission**, **such as through the use of SSL/TLS.**
- The **use of secure, trusted network connections** rather than open or unsecured public networks.

Network Attacks – *Birthday Attack*

- A Birthday Attack refers to **a cryptographic attack that exploits the mathematical principles underlying the *birthday problem* in probability theory**.
- It utilises ***collision***, which is a condition in which **two different inputs produce identical output after processed through a *hash function***.
- **A hash function converts an input of any size into a fixed-size output, referred to as a *hash value*** or ***digest***.

Network Attacks – *Birthday Attack -- Working*

- A birthday attack **systematically generates a large number of input variations and compares their resulting hash values, in order to identify a collision.**

- A successful birthday attack **may allow an adversary to substitute a fraudulent document or message for a legitimate one, provided both produce the same hash value**.

Network Attacks – *Birthday Attack -- Prevention*

- This attack is **mitigated through the use of hash functions that produce a sufficiently large output size**, as **the difficulty of finding a collision increases substantially with the length of the hash value produced**.

- ***Salting,*** it is a **process in which a random data added to a password or input before hashing to ensure unique outputs and stop precomputed dictionary or rainbow table**.

Network Attacks – *Malware Attacks*

- **Malware Attacks refer to the broad category of attacks in which malicious software is employed to compromise the confidentiality, integrity, or availability of a target system or network.**

Network Attacks – *Malware Attacks -- Forms*

- **Malware attacks encompasses several specific forms of malicious software, including:**
  - **Viruses**, which **attach themselves to legitimate files and require user action to spread.**
  - **Worms**, which **self-replicate and spread autonomously across networks without requiring user action**.

Network Attacks – *Malware Attacks -- Forms*

- **Trojan Horses**, which **disguise themselves as legitimate software in order to deceive users into installing them**.
- **Ransomware**, a further **category of malware that encrypts a victim's data and demands payment in exchange for restoring access.**
- **Spyware**, malware **designed to covertly monitor and record a user's activity**, often **for collecting confidential information without the user's knowledge.**

Network Attacks – *Malware Attacks -- Consequences*

- **Unauthorized access to systems and data,**
- **Data corruption or loss**
- **Degradation of system performance**
- **The establishment of unauthorized remote access for the attacker**

Network Attacks – *Malware Attacks – Prevention measures*

- **The use of updated antivirus and anti-malware software**
- **Regular application of security patches**
- **Restriction of software installation privileges**
- **User education regarding safe handling of email attachments and downloaded files**

Network Attacks – *Social Engineering Attacks -- Forms*

- **Phishing:** The **use of fraudulent communications impersonating a trusted source to induce disclosure of confidential information**. It is performed in **mass scale**.

- **Pretexting**: The **fabrication of a plausible scenario or false identity by an adversary, in order to gain the trust of a victim and induce them to disclose information or perform an action**. It is **personalized**.

Network Attacks – *Social Engineering Attacks*

- Social Engineering Attacks refer to **attacks that rely primarily on the psychological manipulation of individuals, rather than the exploitation of technical vulnerabilities**.

- It can induce victims to **disclose confidential information or to perform actions that compromise security**.

Network Attacks – *Social Engineering Attacks – Forms (contd.)*

- **Baiting**: The **offering of a false incentive, such as a free item or an infected physical storage device left in a conspicuous location**.

- **Tailgating**: The **unauthorized physical entry of an adversary into a restricted area, achieved by closely following an authorized individual through a secured access**.

Network Attacks – *Social Engineering Attacks – Forms (contd.)*

- **Impersonating**: the act of an **adversary presenting themselves as a legitimate, trusted individual or authority in order to gain unauthorized access or induce a victim to comply with a request**.

Network Attacks – *Social Engineering Attacks -- Prevention measures*

- **User awareness and training programs**
- **Establishment and enforcement of clear organizational procedures for verifying identity prior to disclosing information**
- **Cultivation of a general culture of caution regarding unsolicited requests for sensitive information or access**

Firewall

- A Firewall refers to a network security system, implemented in hardware, software, or a combination thereof,

- Firewall monitors and controls incoming and outgoing network traffic based on a predefined set of security rules.

Firewall – *Principal Functions*

- **Traffic filtering: The examination of incoming and outgoing data packets against a defined set of rules.**

- **Access control: The restriction of network access to only those services, ports, and connections that are explicitly authorized.**

Firewall – *Principal Functions*

- **Logging and monitoring: The recording of network traffic and security events, thereby facilitating the detection of suspicious activity and supporting subsequent investigation.**

Firewall – *Types*

- **Packet-Filtering Firewall**: This type of firewall **examines individual data packets in isolation, evaluating each against a set of predefined rules based on attributes such as source and destination IP address, port number, and protocol**, and subsequently permitting or denying each packet accordingly.

Firewall – *Types (contd.)*

- **Stateful Inspection Firewall**: This type of firewall **monitors the complete state of active network connections, rather than examining individual packets in isolation**, and **makes filtering decisions based on the context of the connection to which a given packet belongs**.

Firewall – *Types (contd.)*

- **Proxy Firewall (Application-Level Gateway)**: This type of firewall functions as an **intermediary between an internal client and an external server, wherein the firewall itself establishes a separate connection with the external server on behalf of the internal client, such that no direct connection is established between the two**.

Firewall – *Types (contd.)*

- **Next-Generation Firewall (NGFW)**: This type of firewall **incorporates the capabilities of traditional firewalls with additional advanced features, including deep packet inspection, intrusion prevention functionality, and the ability to identify and control traffic based on the specific application generating it.**

Firewall – *Types (contd.)*

- **Circuit-Level Gateway**: This type of firewall **verifies and monitors the establishment of a connection (such as the TCP handshake process) between two parties, without examining the content of individual packets exchanged during the session**.

Firewall – *Types (contd.)*

- **Software Firewall: Firewall implemented as an application installed on an individual computing device**. commonly used to **protect individual personal computers or servers**.

- **Hardware Firewall: Firewall implemented as a dedicated physical device, positioned at the boundary of a network, providing protection for all devices connected to that network. Commonly deployed at the perimeter of organizational networks.**